

- Default or blank passwords.
- DoS attacks against the TCP/IP stack using invalid packets.
- Various misconfigurations, including old software versions and open mail relay.
- Various vulnerabilities that may allow a hacker to damage a system.

Nessus is free of charge for personal use.

## Your firewall

A properly configured firewall can protect your network from possible threats; it will keep external attackers out of your network. You should not forget to check the log files of your firewall software or hardware for odd error messages. I use the firewall capabilities of my Cisco ADSL router to protect my home network.

## SQLMap

Nowadays, almost every website uses a database to store and retrieve data. SQLMap is an open source penetration-testing tool for detecting and exploiting SQL injection flaws. It supports MySQL, Oracle, DB2, SQLite, PostgreSQL, Firebird and Sybase.

## Aircrack-ng

Aircrack-ng is a set of tools for auditing wireless networks. It supports WEP and WPA-PSK key-cracking. Your wireless network interface should support raw monitoring mode in order to work with it. It can capture 802.11a, 802.11b and 802.11g traffic.

## Telnet

The initial purpose of Telnet was to allow users to connect and control machines remotely. The Telnet protocol uses a plaintext TCP connection to transmit and receive data—so when SSH, which uses encrypted and secure connections, was introduced, administrators switched from Telnet to SSH. Telnet is now rarely used to remotely access a UNIX machine, but can still be used for troubleshooting TCP/IP networks and services.

The main benefit of using Telnet (run *man telnet* to see its man page) to manually simulate client-server interactions is that you see the raw data of the connection. Using Telnet to connect to a POP3 server or a website is better for troubleshooting because you see raw output, including control data, and therefore you can better comprehend the problem itself. For example, the following is the output of a successful POP3 transaction using Telnet:

```
$ telnet mail.SOMEDOMAIN.gr 110
Trying 194.63.zzz.xxx...
Connected to mail.SOMEDOMAIN.gr (194.63.zzz.xxx).
Escape character is '^J'.
+OK Greek Schools Network Mail Service (SCH) POP3 ready
USER tsoukalos
+OK
PASS xxxxyyyzzz
+OK Logged in.
```

LIST

+OK 108 messages:

1 1813

2 1816

3 143641

~

107 93059

108 3242

.

quit

+OK Logging out.

Connection closed by foreign host.

## Log files

This is not an actual tool, but log files are a very useful source of security-related messages that you should regularly check for abnormal messages. It is recommended that you create small scripts, in your preferred scripting language, to extract unusual messages from your log files.

The following simple *grep -w* command displays the *sudo* (*man sudo*) related information found in the *system.log* file:

```
$ grep -w sudo system.log
```

## The 'John the Ripper' password cracker

Weak passwords are the No 1 security threat, so it is part of your job as a UNIX administrator to check for weak or empty passwords, and protect your Linux machines. The 'John the Ripper' utility can check if a password is easy to guess by trying to crack it using the brute-force method.

## Summary

All the tools mentioned are very handy for system or network administration, and I think that you should add them to your arsenal of tools. When checking the security of a machine or a network, I suggest that you start with Nmap—and never forget that those tools are also available to attackers. **END** 

## Web links/bibliography

- WireShark: [www.wireshark.org/](http://www.wireshark.org/)
- TCPDump and libpcap site: [www.tcpdump.org/](http://www.tcpdump.org/)
- Internetworking with TCP/IP, Volume 1, Douglas E. Comer, Prentice Hall
- John the Ripper password cracker: [www.openwall.com/john/](http://www.openwall.com/john/)
- Nessus: [www.nessus.org](http://www.nessus.org)
- Apache log files: <http://d.apache.org/docs/2.2/logs.html>
- SQLMap: [sqlmap.org/](http://sqlmap.org/)
- Aircrack-ng: [www.aircrack-ng.org/](http://www.aircrack-ng.org/)
- TELNET RFC: [tools.ietf.org/html/rfc854](http://tools.ietf.org/html/rfc854)
- Nmap: [nmap.org](http://nmap.org)

## By: Mihalis Tsoukalos

The author enjoys photography, writing articles, programming iOS devices and administering UNIX machines. You can reach him at [tsoukalos@sch.gr](mailto:tsoukalos@sch.gr) and [@mactsouk](mailto:@mactsouk).